J&J ACELERAÇÃO CYBERSECURITY

Identity and Access Management (IAM)

Gestão de credenciais e cofres de segredos

Material didático do aluno

Módulo IAM: 40 horas | Semanas 4-5
Nível básico/intermediário

Objetivo de aprendizagem

Proteger segredos com vaults.

Continuação da aula sobre identidades não humanas: serviços, chaves e tokens. Da identificação da carga de trabalho à entrega segura da credencial e à resposta a vazamentos.

Como você vai aprender

Explicações progressivas, tabelas, exemplos corporativos, microtarefas, simulação guiada, estudo de caso e desafio final. Atividades sem credenciais reais, sem instalação obrigatória e sem nuvem paga. Autoavaliação sem gabarito.

2026

Português brasileiro | Edição de estudo

1. Percurso de aprendizagem

Na aula anterior, você estudou quem atua em nome de um serviço. Agora, vamos acompanhar o material que permite esse acesso: onde nasce, quem pode obtê-lo, por quanto tempo funciona e como é retirado de circulação.

Bloco	Onde estudar	Resultado esperado
Reconhecer	Páginas 3-5	Distinguir credenciais, segredos e locais de exposição.
Projetar	Páginas 6-10	Explicar cofre, criptografia, políticas e confiança inicial.
Operar	Páginas 11-16	Planejar ciclo de vida, consumo, auditoria e continuidade.
Comparar e avaliar	Páginas 17-19	Comparar soluções, riscos e resposta a incidentes.
Praticar	Páginas 20-25	Corrigir exemplos, propor políticas, simular rotação e analisar um caso.
Demonstrar	Páginas 26-29	Desenhar arquitetura, revisar práticas e avaliar a aprendizagem.
Consultar	Páginas 30-31	Acessar referências técnicas oficiais.

O que demonstra que você aprendeu

Ao concluir, você deverá justificar onde guardar cada segredo, desenhar a autenticação do workload, limitar acessos por ambiente, planejar rotação e revogação e produzir evidências sem revelar valores confidenciais.

Organização sugerida

Estude os fundamentos antes da simulação. Reserve aproximadamente 60 minutos para as quatro etapas práticas, 20 para o caso e 30 para o desafio. Os tempos são sugestões de estudo; não alteram a carga horária oficial do módulo.

Combinado da aula

Use papel ou editor de texto. Todos os nomes, valores, políticas, prazos e eventos dos exercícios são fictícios. Não representam sistemas ou políticas internas da J&J. Os trechos são pseudocódigo didático, sem finalidade de implantação direta.

2. Credencial, segredo e identidade

Identidade representa quem ou o que atua. **Credencial** é um elemento, ou conjunto de elementos, usado para comprovar uma identidade ou sustentar acesso. **Segredo** é informação cujo valor deve permanecer confidencial para manter a proteção esperada.

Um workload é uma carga de trabalho, como uma API, um robô ou um processo de integração. Ele pode ter uma identidade estável e trocar suas credenciais muitas vezes. O responsável humano continua acompanhando finalidade, permissões e desligamento.

Elemento	Exemplo fictício	Como tratar
Identidade	svc-pedidos-prod	Registrar responsável e finalidade. O nome não é uma senha.
Referência ao segredo	prod/pedidos/banco	Indica onde buscar. Pode revelar estrutura interna, mas não é o valor.
Valor secreto	VALOR_FICTICIO_DB_A	Proteger leitura, cópias, uso e descarte.
Metadados	Responsável, versão, data e finalidade	Usar para gestão, com acesso apropriado; não inserir valores secretos.
Permissão	Ler pedidos no banco	Definir no recurso de destino; acesso ao cofre não substitui essa regra.

Uma analogia com limites

O cofre se parece com uma portaria que entrega uma chave apenas a quem tem autorização. Porém, uma cópia já entregue pode continuar funcionando na porta. Por isso, apagar a chave da portaria não basta: é preciso invalidá-la na fechadura, isto é, no sistema que a aceita.

Microtarefa 1

Em uma integração de estoque, identifique: workload, identidade, responsável, referência do segredo, valor secreto e recurso acessado. Explique qual desses elementos muda durante uma rotação.

3. Senhas, tokens, chaves e certificados

Termo	O que é e como aparece	Cuidado principal
Senha	Valor compartilhado verificado pelo sistema. Pode autenticar pessoa ou serviço.	Não reutilizar entre ambientes; evitar compartilhamento sem rastreabilidade.
Token	Artefato emitido para uma finalidade, como acessar uma API durante certo prazo.	Token bearer permite uso por quem o possui. Verificar escopo, destinatário e validade.
Chave de API	Valor associado a cliente, projeto ou aplicação; significado depende da API.	Pode autorizar chamadas e gerar custos. Não presumir validade curta ou escopo restrito.
Chave privada	Parte secreta de um par criptográfico, usada para assinar ou provar posse.	Não confundir com chave pública. Preferir operação protegida sem exportação quando possível.
Certificado digital	Documento assinado que vincula uma chave pública a uma identidade ou a atributos.	O certificado público não é normalmente segredo. Arquivo que inclui chave privada exige proteção.
Segredo	Categoria ampla: senhas, tokens confidenciais, chaves privadas e outros valores sensíveis.	Nem toda credencial é inteiramente secreta; avalie seus componentes.

Um arquivo .p12 ou .pfx pode reunir certificado e chave privada. O nome da extensão não basta para determinar o conteúdo. Um certificado, sozinho, não prova posse da chave privada correspondente.

Dois enganos frequentes

Base64 é codificação, não criptografia. Um JWT assinado pode ter conteúdo legível: assinatura protege integridade e autenticidade conforme a validação, mas não torna o conteúdo confidencial. Não coloque senhas dentro dele.

Microtarefa 2

Classifique como secreto, público ou dependente do conteúdo: client_id, certificado público, chave privada, token bearer e arquivo .pfx. Justifique sem copiar nenhum valor real.

4. Onde os segredos escapam

Uma credencial pode estar bem protegida no cofre e vazar depois de ser entregue. Avalie todo o caminho, incluindo ferramentas que copiam arquivos, registram erros ou guardam resultados de execução.

Local	Como ocorre a exposição	Correção proposta
Código e Git	Senha literal, histórico, branches, forks ou revisão de código.	Guardar referência; detectar segredos antes e depois do commit; revogar valor exposto.
Arquivo .env	Texto legível enviado por chat, backup, pacote ou pasta pública.	Não versionar; restringir acesso; usar apenas quando necessário e controlar distribuição.
Logs e traces	Impressão de cabeçalhos, conexão, ambiente ou exceções completas.	Registrar campos permitidos; excluir valores e verificar agentes de observabilidade.
Imagem de container	COPY de arquivo secreto ou valor em ENV, ARG, camadas e cache.	Usar entrega em execução ou mecanismo de segredo de build; revisar artefatos.
Pipeline CI/CD	Job malicioso, runner compartilhado, saída de depuração ou artefato publicado.	Limitar job, identidade e ambiente; proteger código e runners.
Tickets e anexos	Capturas de tela, planilhas de inventário e conversas de suporte.	Usar identificadores administrativos e evidências sob acesso controlado.

Colocar .env no .gitignore reduz novos commits acidentais; não remove cópias já rastreadas nem histórico. Um repositório privado também pode ter acessos excessivos ou contas comprometidas.

A máscara não é uma barreira completa

Ocultar um valor conhecido na tela ajuda, mas transformações, fragmentos ou formatos inesperados podem escapar do mascaramento. A defesa principal é não produzir a saída sensível.

Microtarefa 3

Uma senha foi removida do arquivo atual e o repositório tornou-se privado. Liste três ações adicionais e explique por que a senha ainda pode funcionar para outra pessoa.

5. O que um vault faz

Um **secret manager**, ou gerenciador de segredos, centraliza armazenamento e entrega sob controle de acesso. **Vault** significa cofre; também integra o nome do produto HashiCorp Vault. Neste material, “cofre” indica o conceito geral.

A centralização facilita inventário e políticas consistentes. Ela exige operação cuidadosa: um cofre indisponível pode afetar serviços, e uma política ampla pode expor muitos segredos de uma vez. [1]

Componente	Função	Pergunta de projeto
API e cliente	Receber solicitações por canal protegido.	Qual aplicação acessa qual endpoint?
Autenticação	Validar a identidade apresentada.	Em quem o cofre confia e como verifica a prova?
Políticas	Decidir ações sobre recursos.	Pode ler, criar, alterar, excluir ou administrar?
Armazenamento protegido	Guardar valores e versões com criptografia.	Quem administra armazenamento e chaves?
Mecanismo de emissão	Gerar credencial, quando integrado ao destino.	O produto emite esse tipo ou só guarda um valor?
Auditoria	Registrar eventos de acesso e gestão.	Quem monitora recusas e mudanças de política?
Operação e recuperação	Manter serviço, backups e restauração.	Como recuperar sem expor segredos antigos?

O que precisa continuar fora da “caixa”

A equipe ainda define responsáveis, permissões no banco, proteção do host, validade, resposta a incidentes e testes. Uma aplicação autorizada e comprometida pode abusar do acesso legítimo ao cofre.

Microtarefa 4

Descreva uma falha que a criptografia do cofre ajuda a reduzir e outra que depende de controle de acesso ou segurança da aplicação. Relacione cada uma a um componente da tabela.

6. Cofre pessoal e cofre corporativo

Gerenciadores de senhas voltados a pessoas ajudam a criar e guardar senhas de login. Cofres de segredos para workloads atendem aplicações e automações. Há produtos com funções sobrepostas; compare capacidades reais, e não apenas o nome comercial.

Critério	Gerenciador pessoal	Cofre corporativo para workloads
Consumidor típico	Pessoa, navegador ou aplicativo de preenchimento.	API, serviço, container ou job automatizado.
Autenticação	Conta humana, senha mestra e/ou outros fatores.	Identidade do workload, federação ou mecanismo de máquina.
Entrega	Consulta ou preenchimento para o usuário.	API, agente ou integração automatizada.
Governança	Organização da vida digital da pessoa.	Responsável por segredo, ambientes e políticas por recurso.
Ciclo de vida	Geração e troca de senhas de uso humano.	Versionamento, rotação coordenada e emissão temporária quando suportada.
Auditoria	Varia conforme produto e plano.	Eventos centralizados de máquinas e administradores, conforme configuração.

Como escolher no contexto certo

Para a senha individual de um portal, a experiência de preenchimento pode ser central. Para uma API com cinquenta instâncias, importam autenticação automática, renovação, entrega sem intervenção e acompanhamento por ambiente.

Exemplo corporativo

A equipe não deve depender do cofre pessoal de quem desenvolveu o sistema para reiniciar a API. A identidade da aplicação e o segredo precisam continuar administráveis quando essa pessoa muda de função ou sai da empresa.

Microtarefa 5

Uma equipe exporta a senha do cofre pessoal e a envia a cada deploy. Quais capacidades ela precisa para substituir esse processo? Cite pelo menos uma de governança e duas de automação.

7. Criptografia, TLS e KMS

Criptografia em repouso protege dados armazenados, como volumes e backups. **Criptografia em trânsito** protege a comunicação, normalmente com TLS. Uma não substitui a outra: proteger o disco não torna segura uma conexão que ignora a validação do servidor.

KMS: gestão das chaves criptográficas

Um **Key Management Service** administra chaves e operações criptográficas. Na criptografia de envelope, uma chave de dados cifra o conteúdo e outra chave protege essa chave de dados. O desenho evita guardar a chave de proteção em claro junto ao conteúdo cifrado. [2]

Recurso	Proteção oferecida	Limite
TLS com validação	Canal protegido e verificação do servidor.	Não impede que um cliente autorizado imprima o valor recebido.
Criptografia em repouso	Reduz exposição pela leitura direta do armazenamento.	Não corrige uma permissão que autoriza leitura pela API.
KMS	Gestão e uso controlado de chaves criptográficas.	Não equivale, por si só, ao ciclo de vida de senhas de banco.
HSM	Módulo de hardware para proteger operações e material criptográfico.	Não dispensa políticas, administração e continuidade.

Depois da leitura autorizada, o segredo pode existir em memória no consumidor. Proteja processos, diagnósticos e dumps. A criptografia do cofre não elimina a exposição no ponto de uso.

Rotacionar qual objeto?

Trocar a chave de criptografia do cofre e trocar a senha do banco são operações diferentes. A primeira atua sobre a proteção criptográfica; a segunda altera o que o banco aceita para autenticação. Planeje e verifique cada uma separadamente.

Microtarefa 6

Um invasor obtém uma identidade com permissão de leitura no cofre. Por que “o dado está criptografado” não responde sozinho ao incidente?

8. Autenticar e autorizar workloads

Autenticação verifica a identidade apresentada. **Autorização** decide o que ela pode fazer. Para uma aplicação, o cofre pode confiar em identidade gerenciada pela plataforma, federação ou certificado, conforme o ambiente e a integração.

RBAC organiza permissões em papéis atribuídos a identidades. **Least privilege**, ou menor privilégio, concede apenas ações e recursos necessários. Políticas podem acrescentar condições de ambiente e origem. No HashiCorp Vault, políticas ACL expressam capacidades sobre caminhos e são associadas por mecanismos de autenticação. [3]

Identidade / papel fictício	Permissão necessária	Limite proposto
API de pedidos - produção	Obter credencial do banco de pedidos de produção.	Sem leitura de segredos de outras aplicações; sem alterar políticas.
Job de publicação - produção	Publicar versão aprovada no ambiente.	Não precisa ler senha de runtime do banco.
Automação de rotação	Atualizar o segredo específico e a credencial no destino.	Sem administrar todos os cofres; execução auditada.
Auditoria	Consultar eventos e metadados autorizados.	Sem ler valores de segredos.
Administrador de políticas	Gerir concessões aprovadas.	Acesso humano forte e mudanças revisadas; avaliar capacidade indireta de obter leitura.

Separe desenvolvimento, homologação e produção com identidades e concessões próprias. Um prefixo no nome ajuda a organizar, mas a separação só existe se políticas e limites efetivos a impõem.

Microtarefa 7

Reescreva “todas as aplicações podem ler todos os segredos” para a API de pedidos. Defina identidade, ação, recurso, ambiente e duas operações que devem ser negadas.

9. Fluxo seguro e confiança inicial

Fluxo conceitual

Aplicação → autenticação de workload → vault → segredo temporário → serviço

O cofre devolve a credencial à aplicação; ela a apresenta ao serviço de destino. O cofre não precisa atuar como intermediário de todas as requisições de negócio.

Etapa	O que acontece
1. Aplicação inicia	A plataforma fornece uma identidade verificável, ou a aplicação usa mecanismo inicial protegido.
2. Autenticação	O emissor/cofre valida prova, emissor, destinatário e contexto aplicáveis. Pode haver token de sessão do próprio cofre.
3. Autorização no vault	A política permite somente a emissão ou leitura solicitada. O evento é auditado sem valor secreto.
4. Entrega temporária	A integração emite uma credencial com prazo e permissões no serviço. A aplicação recebe valor e metadados de validade.
5. Uso no destino	O serviço autentica a credencial e aplica suas próprias permissões. A aplicação renova ou obtém outra antes de expirar.

Bootstrap: de onde vem a primeira prova?

Bootstrap é o estabelecimento da confiança inicial. Guardar no código uma senha permanente para abrir o cofre apenas desloca o problema. Prefira identidade gerenciada ou federação quando disponíveis. Restrinja a confiança ao workload e contexto previstos, e proteja quem pode alterar esses vínculos.

Se um legado exige segredo inicial, entregue-o por canal controlado, limite seu alcance e validade quando possível e planeje substituição. Não use token administrativo do cofre como credencial de aplicação.

Duas condições indispensáveis

O fluxo temporário depende de suporte real do emissor e do destino. Um cofre que apenas armazena uma senha estática não a torna temporária. Em nenhuma etapa registre valores em logs, traces ou mensagens de erro.

10. Ciclo de vida do segredo

O ciclo começa antes da geração e termina depois da retirada. Para cada segredo, acompanhe finalidade, responsável, consumidores, ambientes e evidência de encerramento. Use o inventário para localizar dependências, sem reproduzir o valor.

Fase	Ação da equipe	Evidência sem segredo
1. Solicitar	Justificar recurso, ações e duração; indicar responsável.	Solicitação e aprovação registradas.
2. Gerar / emitir	Criar valor por mecanismo apropriado; evitar escolha previsível.	ID, emissor e data de criação.
3. Armazenar	Gravar no cofre com política e proteção definidas.	Referência, versão e responsável.
4. Distribuir / usar	Entregar somente ao consumidor autenticado.	Evento de acesso e teste de permissão.
5. Monitorar	Acompanhar uso, prazo, falhas e acessos inesperados.	Alerta e revisão de permissões.
6. Rotacionar / renovar	Coordenar mudança com consumidores ou renovar concessão permitida.	Registro de teste e próxima revisão.
7. Revogar / expirar	Encerrar validade no sistema que aceita a credencial.	Teste de recusa e verificação de sessões.
8. Descartar	Retirar cópias, versões e dependências conforme retenção.	Encerramento aprovado e rastreável.

Inventário mínimo

Referência do segredo; tipo; sistema e ambiente; proprietário e substituto; consumidor; emissor/destino; permissões; data ou condição de expiração; plano de rotação; forma de revogação; localização de auditoria; dependências de recuperação.

Microtarefa 8

Monte uma ficha para “prod/pedidos/transportadora”, uma chave de API fictícia. Quais informações faltantes impediriam uma troca segura? Como descobrir essas informações sem pedir o valor da chave?

11. Versão, rotação e revogação

Conceito	Significado	Não confundir com...
Versionamento	Guardar revisões distintas do valor no cofre.	Invalidar automaticamente o valor anterior no destino.
Rotação	Substituir a credencial e coordenar o uso da nova.	Apenas gravar outro texto no cofre.
Expiração	Encerrar validade conforme prazo aplicado pelo sistema.	Uma etiqueta de data que ninguém faz cumprir.
Revogação	Retirar validade antes do prazo previsto.	Apagar a cópia do cofre e manter a credencial ativa.
Renovação	Estender uma concessão permitida, dentro de limites.	Necessariamente emitir um valor diferente.

O KV v2 do HashiCorp Vault armazena segredos estáticos com versões; diferencia exclusão recuperável de destruição da versão. Essas ações sobre armazenamento não trocam, por si só, a senha do sistema externo. [4]

Exemplo de rotação coordenada

A API usa a versão A. A equipe prepara B no destino e no cofre, testa B, migra consumidores e invalida A após a transição aprovada. Se o destino não aceita duas credenciais simultâneas, será necessário outro mecanismo ou uma janela de manutenção. Não presuma suporte à sobreposição.

Defina periodicidade pelo risco, capacidade do destino e dependências, além de gatilhos como suspeita de exposição. Prazos usados nos exercícios são hipóteses didáticas, não uma regra universal.

Revogação precisa de comprovação

Verifique recusa no serviço e avalie sessões, conexões abertas e tokens derivados. Trocar a senha pode não encerrar conexões já estabelecidas. A propagação e o encerramento dependem da implementação.

Microtarefa 9

Um painel informa “nova versão criada”. Que evidências faltam para declarar a rotação concluída? Inclua consumidores, destino e valor anterior.

12. Segredos dinâmicos e temporários

Dinâmico descreve uma credencial gerada sob demanda por uma integração. **Temporário** descreve validade limitada. Uma credencial pode ser ambos. Uma senha estática guardada em um cofre continua estática até que um processo a substitua.

No mecanismo de banco de dados do HashiCorp Vault, papéis configurados orientam a geração de credenciais específicas. A integração precisa de autorização no banco para administrar os usuários envolvidos. Esse acesso administrativo também merece proteção e rotação. [5]

Modelo	Exemplo fictício	Implicação
Estático versionado	Chave de uma transportadora guardada no cofre.	Rotação depende também da API da transportadora.
Dinâmico	Usuário de banco criado para uma execução autorizada.	Melhora atribuição do uso; exige integração e revogação no banco.
Temporário	Token de acesso válido por 15 minutos.	Reduz janela de uso de uma cópia, mas pode ser roubado durante a validade.

TTL, lease e renovação

TTL é o tempo de vida. **Lease** é a concessão acompanhada pelo cofre, com prazo e informações de gestão. No Vault, leases de segredos dinâmicos permitem renovação quando suportada e revogação; segredos estáticos KV não recebem o mesmo ciclo automático de lease. [6]

Exemplo de raciocínio temporal

Em um exercício, a API recebe credencial às 10h com TTL de 15 minutos. Às 10h12, tenta renovar ou obter outra. Se a tentativa falhar, deve aplicar a política de continuidade e respeitar a validade; não manter a credencial indefinidamente por conveniência.

Microtarefa 10

Qual risco permanece se o atacante controla o workload e consegue pedir novos tokens a cada 15 minutos? Proponha contenção sobre a identidade e sobre o destino.

13. Consumo seguro por aplicações

A aplicação deve saber qual segredo precisa e como obter autorização para lê-lo. Evite listas gerais de segredos, credenciais embutidas e recuperação de valores que a função não utiliza.

Padrão	Como funciona	Cuidados
API / SDK	Cliente autenticado consulta o cofre em execução.	Tratar falhas, validade, limites de requisição e atualização; impedir logs de respostas.
Agente / sidecar	Processo auxiliar autentica e disponibiliza o segredo.	Proteger canal ou arquivo local; limitar quem lê; verificar recarga pela aplicação.
Arquivo montado	Valor aparece em caminho restrito durante a execução.	Permissões mínimas, armazenamento adequado, retirada e atualização; evitar backups.
Variável de ambiente	Plataforma injeta valor no processo.	Pode aparecer em diagnósticos e ser herdado; mudança pode exigir reinício. Não é cofre.

A documentação do Google Secret Manager recomenda acesso direto por API e destaca riscos de arquivos e variáveis de ambiente. Integrações específicas podem usar esses mecanismos; a decisão deve considerar quem consegue ler cada cópia. [7]

Pseudofluxo de consumo

1. Obter identidade do workload por mecanismo aprovado.
2. Solicitar somente a referência necessária por canal validado.
3. Receber credencial e validade; usar no destino autorizado.
4. Manter cache limitado, se necessário; atualizar antes do vencimento.
5. Registrar sucesso ou falha com identificador, nunca com o valor.

Cache é uma cópia temporária que reduz consultas e dependência imediata do cofre. Defina prazo máximo, invalidação e comportamento em incidente. Não presuma que uma cópia em cache será retirada só porque o acesso ao cofre foi bloqueado.

14. CI/CD, containers e serviços

CI/CD automatiza integração, testes e publicação. O job que publica a aplicação e a aplicação em produção exercem funções diferentes; use identidades e concessões compatíveis com cada função.

Pipeline com confiança delimitada

Federação OIDC pode permitir que um job troque uma prova emitida pela plataforma por credenciais temporárias. A confiança precisa restringir repositório, contexto e ambiente esperados. Proteger o workflow e quem pode modificá-lo faz parte da proteção do acesso. [8]

Jobs que executam código não confiável, como contribuições externas, não devem receber segredos de produção. Reduza persistência em runners, limpe áreas temporárias e controle plugins, dependências e artefatos. Aprovação de deploy não deve se resumir a esconder uma variável.

Build e execução são momentos diferentes

Durante o build, use mecanismos próprios de segredo temporário, como secret mounts do BuildKit, quando necessários. Não use ARG, ENV ou COPY para incorporar credenciais. Mesmo com mount, o comando pode copiar ou imprimir o segredo: revise sua saída e os arquivos gerados. [9]

Durante a execução, prefira identidade do workload e obtenção controlada. Excluir um arquivo em uma camada posterior da imagem não garante remover sua cópia das camadas anteriores.

Kubernetes não transforma codificação em proteção

Um objeto Kubernetes Secret exige controle de acesso e criptografia em repouso configurada conforme o ambiente. Base64 não oferece confidencialidade. Restrinja também quem cria workloads capazes de montar segredos e quem acessa os containers. [10]

Microtarefa 11

O pipeline precisa publicar a imagem, mas hoje lê a senha do banco de produção. Desenhe um fluxo em que a imagem seja construída sem essa senha e a aplicação a obtenha apenas em execução.

15. Auditoria e continuidade

Eventos úteis, valores ausentes

Registre identidade, referência administrativa do segredo, ação, horário, origem relevante, resultado e ID de correlação. Não registre senha, token bearer, chave privada ou string de conexão completa. Limite acesso e retenção dos registros. A OWASP também recomenda excluir dados sensíveis e proteger os logs contra alteração indevida. [11]

Sinal	Interpretação a investigar	Ação inicial
Muitas leituras incomuns	Nova versão com defeito ou coleta indevida.	Comparar com deploys, identidade e padrão de uso.
Recusas entre ambientes	Erro de configuração ou tentativa de ultrapassar limites.	Verificar origem e política; não ampliar acesso automaticamente.
Política alterada	Mudança aprovada ou elevação indevida.	Vincular a solicitação e revisar acesso efetivo.
Falha de renovação / rotação	Dependência indisponível ou credencial divergente.	Acionar responsável e plano de continuidade.

Se o cofre ficar indisponível

Defina tentativas limitadas com espaçamento, alerta e uso de cache somente dentro da validade e da política aprovada. Serviços podem parar operações dependentes do segredo e manter funções seguras. Não crie fallback com senha fixa no código.

Planeje disponibilidade, backups protegidos e testes de restauração. Verifique se a recuperação reintroduziria versões ou permissões antigas. O acesso emergencial, ou *break-glass*, deve ter escopo e prazo limitados, justificativa, auditoria e revisão posterior.

Microtarefa 12

Proponha um evento de auditoria para leitura negada e um para rotação concluída. Que campos permitem investigar sem registrar o segredo? Qual alerta indica possível indisponibilidade?

16. Exemplos de soluções

Os produtos abaixo ilustram modelos de gestão. Não é necessário criar contas para esta aula. Recursos dependem da configuração e da integração; compare comportamento, responsabilidades operacionais e suporte ao destino.

Solução	Exemplo de uso	O que confirmar
HashiCorp Vault	KV v2 para valores estáticos; engine de banco para credenciais dinâmicas. [4][5]	Método de autenticação, políticas por caminho, operação e suporte do plugin ao banco.
AWS Secrets Manager	Armazenamento de segredos, proteção com KMS e acesso por IAM. Suporta rotação configurada. [12]	Integração de rotação, permissões, consumidores e política da chave KMS.
Azure Key Vault	Gestão de segredos, chaves e certificados; workloads podem usar identidades gerenciadas. [13]	Distinguir operações de chave das de segredo e configurar acesso para a finalidade.
Google Secret Manager	Versões e acesso por IAM; integração com identidades da plataforma ou federação. [7]	Separação de ambientes, acesso à versão e atualização dos consumidores.

Armazenamento, aviso e troca são funções distintas

No agendamento de rotação documentado para Google Secret Manager, a notificação SECRET_ROTATE é enviada a tópicos Pub/Sub. O fluxo que recebe o evento precisa executar a troca no destino e criar a versão correspondente; não trate o aviso como evidência de conclusão. Integrações específicas devem ser verificadas separadamente. [14]

Perguntas para qualquer produto

Ele guarda, emite ou apenas referencia o segredo? Como o workload se autentica? Quem altera políticas? Qual operação invalida o valor no destino? Como testar a atualização sem revelar o conteúdo?

17. Matriz de riscos e controles

A matriz é uma proposta didática para priorização. A criticidade real depende do alcance, do prazo de validade, do sistema afetado e das evidências. Um controle reduz risco; sua existência precisa ser verificada.

Risco / efeito	Controle proposto	Evidência e risco residual
Credencial em Git Uso por terceiros.	Detecção, prevenção de commit e revogação no destino.	Teste de recusa; cópias e tokens derivados ainda precisam de análise.
Permissão ampla Exposição de vários sistemas.	Menor privilégio, separação por ambiente e revisão.	Testes negados entre aplicações; workload autorizado ainda pode ser comprometido.
Segredo em log Ampliação do público com acesso.	Campos permitidos e proteção da observabilidade.	Teste com marcador fictício; dependências podem gerar saídas novas.
Segredo em imagem Distribuição pelo registry.	Build sem valor persistido, inspeção de camadas e runtime seguro.	Inspeção do artefato; comando de build malicioso ainda pode copiar o valor.
Rotação incompleta Falha do serviço ou valor antigo ativo.	Inventário de consumidores, transição e invalidação.	Nova credencial funciona e antiga falha; sessões abertas exigem avaliação.
Comprometimento do workload Leituras legítimas abusadas.	Proteção do host, prazo curto, escopo mínimo e detecção.	Eventos correlacionados; bloquear emissão e conter a execução.
Cofre indisponível Interrupção operacional.	Disponibilidade, cache limitado e recuperação testada.	Ensaio de falha; dependências externas podem continuar indisponíveis.

Microtarefa 13

Escolha dois riscos. Indique responsável, prioridade justificada, ação verificável e risco residual. Explique por que comprar um cofre não encerra o tratamento desses riscos.

18. Resposta a vazamento de credencial

Ao identificar possível exposição, acione o processo de incidentes. Não tente confirmar o valor colando-o em sites externos ou espalhando-o em canais de suporte. Trate evidências com acesso restrito e trabalhe com identificadores.

Etapa	Decisão e ação
1. Identificar e delimitar	Mapear credencial, identidade, ambiente, permissões, período e locais de exposição. Distinguir fato de hipótese.
2. Conter	Revogar ou desativar no destino; bloquear emissão adicional e acesso do workload suspeito. Coordenar impacto operacional sem atrasar contenção necessária.
3. Preservar evidências	Guardar eventos, IDs, horários e referências a artefatos sob controle. Preservar o necessário sem manter exposição pública.
4. Investigar alcance	Buscar uso indevido, sessões, tokens derivados, acessos laterais e alterações de política. Falta de log não comprova ausência de abuso.
5. Recuperar	Corrigir origem, emitir nova credencial, atualizar consumidores e verificar rejeição da anterior. Evitar reusar material comprometido.
6. Aprender e acompanhar	Revisar controles, detectar recorrência e registrar ações com responsáveis e prazos. Acionar áreas internas pertinentes ao impacto.

A ordem depende do incidente

Preservação e contenção podem ocorrer em paralelo. Não mantenha uma credencial comprometida válida apenas para observar o atacante. Avalie com a equipe responsável as dependências críticas e as alternativas de continuidade.

Remover um commit, apagar um log ou destruir uma versão do cofre não prova revogação. Investigue caches, clones, imagens, artefatos e backups. Proteja a evidência necessária e elimine exposição indevida conforme o procedimento adotado.

Microtarefa 14

Uma chave vazou há duas horas e foi substituída. A aplicação funciona. Quais três verificações ainda faltam antes de encerrar o incidente?

19. Simulação guiada: preparação

Tempo sugerido: 60 minutos para as etapas das páginas 21-24. A empresa fictícia Aurora Distribuição possui API de pedidos, banco, integração com transportadora e pipeline CI/CD. Trabalhe individualmente ou em dupla, usando apenas papel ou editor de texto.

Ambiente seguro de aprendizagem

Não execute conexões nem comandos em sistemas reais. Não crie contas de nuvem. Os valores FICTICIO_* são marcadores sem validade, e os caminhos são nomes lógicos. A atividade simula decisões, regras e testes; não implementa um cofre criptográfico.

Elemento	Requisito do cenário
API de pedidos	Ler e registrar pedidos no banco do próprio ambiente; chamar a transportadora.
Banco de dados	Permitir as operações de negócio necessárias; API não administra usuários nem estrutura.
Pipeline	Testar em desenvolvimento e publicar versão aprovada. Não consultar dados de pedidos em produção.
Ambientes	dev, hml e prod; credenciais e identidades separadas.
Transportadora	Aceita chave estática; permite duas chaves ativas durante uma transição de até 10 minutos.
Equipe	Aplicações mantém consumidores; Plataforma opera o cofre; Segurança revisa controles e eventos.

Prepare quatro folhas ou seções

A. Diagnóstico: item, classificação, risco, correção e verificação.
B. Política: identidade, recurso, ação, condição e resultado esperado.
C. Rotação: etapa, responsável, prazo e evidência.
D. Testes: cenário, resultado esperado, resultado simulado e justificativa.

Comece com o diagnóstico, construa a política, planeje a rotação e execute a simulação de mesa. Use o requisito como justificativa. Quando precisar de uma hipótese adicional, escreva-a de forma explícita.

20. Etapa A: classificar e corrigir

15 minutos. Para cada cartão, classifique o material como segredo, identificador, configuração ou dependente do conteúdo. Identifique exposição e escreva uma versão corrigida em linguagem natural ou pseudocódigo.

Cartão	Exemplo fictício encontrado
A1 - código	DB_PASSWORD = "FICTICIO_DB_PROD_A"
A2 - .env no Git	API_KEY=FICTICIO_TRANSP_A Arquivo presente no histórico compartilhado.
A3 - log	logger.info("Authorization: Bearer FICTICIO_TOKEN")
A4 - container	COPY .env /app/.env Uma etapa posterior apaga o arquivo.
A5 - pipeline	Job de teste de contribuição externa recebe segredo de prod e imprime variáveis para depuração.
A6 - configuração	SECRET_REF="dev/pedidos/banco" CLIENT_ID="svc-pedidos-dev"
A7 - arquivo	integracao.pfx: conteúdo ainda não inspecionado; chamado de suporte o trata como público.
A8 - política	Identidade svc-pedidos-dev pode ler qualquer caminho de todos os ambientes.

Procedimento

1. Identifique qual função precisa do acesso.
2. Separe o valor de sua referência e de sua identidade.
3. Proponha armazenamento, entrega e concessão compatíveis.
4. Se houve exposição, inclua invalidação no destino e análise de cópias.
5. Defina uma evidência que não contenha valores secretos.

Formato da resposta

Cartão: ____ | Classificação: ____ | Risco: ____
Correção proposta: ____ | Como verificar: ____
Hipótese ou informação que falta: ____

Não basta escrever “usar vault”. Mostre qual identidade obtém qual referência e em que momento. Não é necessário escrever comandos de fornecedor.

21. Etapa B: construir políticas

15 minutos. Use os requisitos da Aurora para criar regras mínimas. Esta é uma linguagem de política fictícia; não é sintaxe de HashiCorp, AWS, Azure ou Google.

Modelo a preencher

identidade: ____
ambiente: ____
recurso ou referência exata: ____
ação permitida: ____
condições de autenticação: ____
prazo ou condição de retirada: ____
demais ações: negar por padrão

Identidade	Tarefa autorizada no cenário	Sua regra / limite
svc-pedidos-dev	Operar API apenas em dev.	_____
svc-pedidos-prod	Operar API apenas em prod.	_____
ci-publicacao-prod	Publicar versão aprovada em prod.	_____
rotacao-transp-prod	Trocar a chave da transportadora em prod.	_____
auditoria	Examinar eventos autorizados.	_____

Verifique duas camadas

Na primeira, decida quem pode ler ou emitir no cofre. Na segunda, determine o que a credencial permite no banco ou na API externa. Se o cofre entrega uma senha de administrador, restringir apenas a leitura não limita os poderes dessa senha no destino.

Escreva também quem pode alterar sua política e como a mudança será revisada. Considere que quem muda regras pode conseguir conceder a si mesmo mais acesso; a separação exige controles efetivos e auditoria.

Entrega desta etapa

Cinco regras justificadas e pelo menos três testes de acesso negado. Inclua tentativa de dev acessar prod, de pipeline obter senha de runtime e de auditoria consultar o valor. Registre o resultado esperado antes de simular.

22. Etapa C: planejar a rotação

15 minutos. Planeje a troca de FICTICIO_TRANSP_A por FICTICIO_TRANSP_B. O destino aceita duas chaves por até 10 minutos. Há três instâncias da API; uma delas só atualiza a configuração ao reiniciar.

Etapa a definir	O que deve constar no seu plano
Preparação	Responsável, consumidores, versão atual, dependências e critério de sucesso.
Criação e registro	Como gerar B no destino e disponibilizar a versão correta no cofre sem expô-la.
Validação inicial	Como testar B com operação autorizada e dados fictícios.
Migração	Ordem de atualização, tratamento da instância que exige reinício e limite da sobreposição.
Conclusão	Como confirmar uso de B e invalidar A no destino.
Falha e recuperação	Quando interromper, quem decide e como recuperar dentro da validade e do risco.
Evidências	IDs de versões e eventos, horários, teste da nova chave e recusa da antiga.

Introduza uma falha no exercício

No minuto 7 da sobreposição, uma instância ainda usa A e a tentativa de atualização falha. Registre sua decisão antes do limite de 10 minutos. Considere retirada da instância, recuperação e impacto ao usuário. Não invente uma extensão de prazo que o fornecedor não oferece.

Variante de incidente

Repita a decisão supondo que A foi exposta publicamente. Uma volta para A pode restaurar funcionamento, mas reabre acesso comprometido. Proponha recuperação com credencial confiável e contenção compatível com o impacto.

Defina ainda o plano para uma credencial de banco temporária com TTL fictício de 15 minutos: quando obter outra, o que fazer em falha e como tratar conexões que permanecem abertas.

23. Etapa D: executar testes de mesa

15 minutos. Um colega representa o workload; outro, o cofre e o serviço. Individualmente, leia cada solicitação e aplique suas regras. Use cartões com referências e validade, sem qualquer credencial real.

Teste	Solicitação ou evento	Registro do aluno
T1	API de prod pede o segredo necessário de seu ambiente.	Esperado: ____ Simulado: ____
T2	API de dev pede a mesma referência de prod.	Esperado: ____ Simulado: ____
T3	Job de publicação tenta ler a senha de runtime.	Esperado: ____ Simulado: ____
T4	Auditoria pede eventos e depois o valor do segredo.	Esperado: ____ Simulado: ____
T5	Credencial temporária ultrapassa sua validade.	Ação no destino: ____
T6	Após a troca, o cliente tenta usar A e depois B.	Resultados: ____
T7	Cofre indisponível e cache vencido.	Decisão: ____
T8	Surge tentativa de imprimir FICTICIO_TRANSP_B.	Correção e evidência: ____

Como registrar o evento

Use: horário fictício, identidade, ambiente, referência, ação, resultado e justificativa. Registre apenas “valor não exibido” onde haveria conteúdo secreto. Compare o resultado com a política e ajuste regras que concedem mais acesso do que o requisito exige.

Critério de conclusão da simulação

Entregue diagnóstico dos oito cartões, cinco políticas, plano de rotação e resultados dos oito testes. A simulação comprova seu raciocínio; não comprova segurança de uma implantação real. Explique qual teste técnico seria necessário para validar cada hipótese relevante.

24. Estudo de caso: o log do deploy

Tempo sugerido: 20 minutos. A Aurora usa um cofre, mas um job de suporte passou a imprimir a configuração completa da API para investigar erros. O log ficou acessível a uma equipe maior do que a autorizada a consultar segredos de produção.

Horário fictício	Fato observado
09h00	Deploy gera log contendo um marcador que representa a chave da transportadora.
09h12	Sistema de monitoramento identifica o padrão sensível.
09h18	Equipe remove a linha do código e restringe acesso ao log.
09h25	Nova versão B é salva no cofre; não há confirmação de mudança no destino.
09h32	Uma instância continua usando a versão A em cache.
09h40	Há chamadas à transportadora de origem ainda não reconhecida.

Perguntas para análise

1. Quais fatos comprovam exposição e quais ainda são hipóteses de abuso?
2. O que deve ser contido no cofre, no workload e no serviço externo?
3. Quais evidências preservar, e como evitar espalhar o valor?
4. Por que criar B no cofre não comprova que a rotação terminou?
5. Como tratar cache, sessões e possíveis tokens derivados?
6. Quais critérios permitem recuperar o serviço e encerrar o incidente?

Entrega do caso

Produza uma linha do tempo comentada e um plano com ações imediatas, de recuperação e de prevenção. Para cada ação, indique responsável, evidência de conclusão e risco residual. Não inclua o valor da credencial na ficha.

25. Desafio final de arquitetura

Tempo sugerido: 30 minutos. Projete a gestão de segredos da Aurora para API, banco de dados, pipeline CI/CD e integração externa em dev, hml e prod. Você pode usar um modelo independente de fornecedor ou uma das soluções estudadas.

Requisitos e restrições

A API lê e grava pedidos; não administra o banco. O pipeline publica versões aprovadas. A integração externa aceita chave estática e duas chaves em transição limitada. A equipe quer credenciais temporárias para o banco onde houver suporte. Nenhum valor secreto deve estar no código, na imagem ou nos logs.

Entregável	Conteúdo obrigatório
Diagrama	Fronteiras dos ambientes, identidades, autenticação inicial, cofre, emissão/leitura e serviço de destino.
Inventário e políticas	Responsáveis, referências e permissões mínimas no cofre e nos recursos. Separar publicação de runtime.
Plano de ciclo de vida	Criação, versão, validade, rotação, revogação, descarte e tratamento da chave estática.
Operação	Eventos sem valores, alertas, indisponibilidade, cache e recuperação.
Validação	Dois testes permitidos, três negados, um de rotação, um de revogação e um de falha do cofre.

Critérios de avaliação: 10 pontos

2 pontos: fluxo e bootstrap explicados.
2 pontos: permissões e ambientes delimitados.
2 pontos: ciclo de vida viável no destino e nos consumidores.
2 pontos: proteção do consumo, auditoria e resposta ao vazamento.
2 pontos: testes verificáveis, continuidade e riscos residuais.

Justificativa final

Em até dez linhas, explique o maior risco residual do seu projeto, a exceção mais relevante e qual evidência seria necessária antes da implantação. Não atribua ao produto uma capacidade que você não verificou.

26. Checklist de boas práticas

Marque **A** = atendido, **P** = pendente ou **NA** = não aplicável com justificativa. Cada pendência deve ter responsável, prazo e evidência. Este checklist apoia revisões; não substitui testes.

Verificação	A / P / NA
Cada segredo tem finalidade, responsável, substituto e consumidores conhecidos.	_____
Inventário contém referências e metadados, sem valores secretos.	_____
Identidades e concessões separam aplicações e ambientes.	_____
Bootstrap evita segredo estático quando há alternativa compatível.	_____
Autenticação e autorização são verificadas no cofre e no destino.	_____
Leitura, escrita, rotação e administração têm escopo mínimo.	_____
TLS é validado; armazenamento, backups e chaves são protegidos.	_____
Não há valores em código, Git, imagens, logs, traces ou artefatos.	_____
Consumo limita cópias e trata cache, validade e atualização.	_____
Pipeline e runtime usam concessões próprias; jobs não confiáveis são isolados.	_____
Rotação inclui destino, consumidores, teste e retirada do valor anterior.	_____
Revogação considera sessões, tokens derivados e novas emissões.	_____
Auditoria, alertas e mudanças de política são acompanhados.	_____
Falha do cofre, restauração e acesso emergencial foram planejados.	_____
Encerramento remove concessões, cópias e dependências desnecessárias.	_____

Registro de uma prioridade

Pendência: _____ Responsável: _____
Prazo: _____ Evidência de conclusão: _____

27. Autoavaliação sem gabarito

Para cada afirmação, marque **0** = ainda não explico; **1** = explico com apoio; **2** = explico e aplico. A pontuação orienta seu estudo; a demonstração prática importa mais que a soma.

Consigo...	0 / 1 / 2
Diferenciar identidade, referência, credencial, segredo e permissão.	_____
Explicar a diferença entre senha, token, chave API, chave privada e certificado.	_____
Identificar exposições em .env, logs, repositórios, imagens e pipelines.	_____
Explicar componentes de um vault e o papel do KMS.	_____
Desenhar autenticação de workload e confiança inicial.	_____
Aplicar RBAC e menor privilégio por aplicação e ambiente.	_____
Diferenciar versionamento, rotação, renovação, expiração e revogação.	_____
Explicar o que torna uma credencial dinâmica ou temporária.	_____
Escolher padrão de consumo e avaliar suas cópias e limitações.	_____
Construir plano de rotação com teste no destino e nos consumidores.	_____
Investigar vazamento sem registrar nem redistribuir valores.	_____
Definir testes de acesso, continuidade e resposta a incidente.	_____

Reflexão individual

Escolha duas afirmações com menor pontuação. Escreva que exemplo você ainda não consegue explicar e qual atividade deste material ajudará a avançar. Depois, selecione uma decisão do desafio para defender com evidências.

28. Perguntas de revisão

Responda com suas palavras. Use exemplos fictícios e justifique as escolhas. Não há gabarito neste material.

1. Por que identidade, credencial e segredo não são sinônimos?

2. Um certificado público precisa ficar secreto? O que muda se o arquivo também contiver a chave privada?

3. Quais riscos permanecem em um .env fora do Git?

4. Como uma aplicação deve obter a primeira prova para acessar o cofre?

5. Por que criptografia em repouso não corrige permissões excessivas?

6. Qual é a diferença entre rotacionar uma chave KMS e uma senha de banco?

7. Como comprovar que uma rotação funcionou sem expor valores?

8. Por que apagar uma versão do cofre pode não revogar a credencial?

9. Que condições tornam útil um segredo dinâmico? O que acontece se a integração não conseguir revogá-lo no destino?

10. Como impedir que um pipeline de desenvolvimento obtenha segredos de produção?

11. Que dados devem constar em um evento de auditoria e quais devem ser excluídos?

12. Como você trataria cofre indisponível, cache vencido e exigência de continuidade?

13. Quais evidências investigaria após vazamento de token temporário?

14. Quando um gerenciador de senhas pessoal deixa de atender ao consumo de uma aplicação?

29. Referências técnicas

Documentação oficial e fontes técnicas consultadas em 21/10/2026. Os números entre colchetes no texto remetem a esta lista. Os títulos sublinhados são links clicáveis.

[1] OWASP. Secrets Management Cheat Sheet.
Visão geral de centralização, operação e gestão de segredos.

[2] Google Cloud. Envelope encryption.
Criptografia de envelope e hierarquia de chaves.

[3] HashiCorp. Vault: Policies.
Políticas, capacidades e associação ao mecanismo de autenticação.

[4] HashiCorp. Vault: Key/Value v2.
Armazenamento de segredos estáticos, versões e exclusão.

[5] HashiCorp. Vault: Database secrets engine.
Geração de credenciais de banco e requisitos da integração.

[6] HashiCorp. Vault: Lease, Renew, and Revoke.
Concessões, renovação, revogação e limites.

[7] Google Cloud. Secret Manager best practices.
Acesso por IAM, identidades e cuidados no consumo.

30. Referências e estudo continuado

Documentação oficial e fontes técnicas consultadas em 21/10/2026. Os números entre colchetes no texto remetem a esta lista. Os títulos sublinhados são links clicáveis.

[8] GitHub Docs. OpenID Connect.
Federação e credenciais temporárias em workflows.

[9] Docker Docs. Build secrets.
Uso de segredos de build e mounts temporários.

[10] Kubernetes. Good practices for Kubernetes Secrets.
Criptografia, acesso e uso por workloads.

[11] OWASP. Logging Cheat Sheet.
Exclusão de dados sensíveis e proteção de registros.

[12] AWS. AWS Secrets Manager best practices.
KMS, IAM, consumo e rotação de segredos.

[13] Microsoft Learn. Azure Key Vault basic concepts.
Segredos, chaves, certificados e identidades gerenciadas.

[14] Google Cloud. Create rotation schedules in Secret Manager.
Notificações de rotação e integração com Pub/Sub.

Como continuar estudando

Escolha uma solução e localize em sua documentação: autenticação de workload, política mínima de leitura, comportamento de versões, rotação e revogação. Compare com seu desafio e anote o que exige validação técnica antes de implantar.

Os cenários, microtarefas, matrizes e roteiros de simulação são construções didáticas. Não constituem uma política corporativa da J&J. Interfaces e recursos de produtos evoluem; consulte a documentação da versão e da integração adotadas.